# Cybersecurity Framework Strategic Recommendations for a Small E-Commerce Retailer

**Prepared by:** Alister A. Rodrigues, Security Analyst, Obsidian SecureTech Solutions

**Client Engagement:** *Crestline Apparel Co.*

September 2024

## Executive Summary

Crestline Apparel Co. is a small US-based e-commerce retailer seeking to establish a robust cybersecurity foundation as it scales its digital operations. However, along with the convenience of e-commerce, it also faces the responsibility of protecting the customer's information, sensitive data, including payment details and personal information, that are entrusted to Crestline Apparel; thus, prioritizing cybersecurity as the scale of business advances.

For the online T-shirt retail store, Obsidian SecureTech Solutions did a comprehensive analysis of two cybersecurity frameworks NIST CSF 2.0 and ISO 27001.

Based on the research and observations provided in this paper, Obsidian SecureTech Solutions would recommend NIST CSF 2.0 as the primary cybersecurity framework for Crestline Apparel as a startup primarily based in the US to support business, IT and security strategies. It is flexible and cost-effective for starter businesses and widely recognized internationally (NIST, 2024 ), also allowing the integration of supplemental guidance from NIST and other government and private sources alike, enabling management and governance of the business with the convenience of a small IT team (NIST Special Publications 800-37, 800-39, and 800-137, 2014).

## Overview of NIST CSF 2.0

The NIST Cybersecurity Framework (CSF) 2.0 is designed to help organizations manage and reduce cybersecurity risks. It provides a structured approach to enhancing security by aligning cybersecurity with business goals. The framework is flexible, applicable across industries, emphasizes risk management, and governance, integrates global standards, and enhances guidance on cybersecurity implementation and supply chain security. Organizations of any size can use the framework to prioritize actions and continuously improve their cybersecurity strategies tailoring it to business-specific needs (NIST, 2024 ).

**Key features**

***Risk-Based Approach***

Focuses on managing cybersecurity risks tailored to organizational needs and threats.

***Flexible and Scalable***

Adaptable for organizations of all sizes and industries, recommended choice for small businesses within the U.S.

***Outcome-Oriented***

Provides a structured, goal-driven framework that aligns cybersecurity efforts with business objectives.

***Lifecycle Coverage***

Addresses the full lifecycle of cybersecurity, from risk identification to recovery and governance.

***Global Alignment***

Integrates with international standards and best practices for wider applicability.

***Prioritization of Actions***

Helps organizations prioritize cybersecurity activities based on risk and impact.

***Supply Chain Focus***

Emphasizes managing cybersecurity risks in the supply chain and third-party relationships.

## Overview of ISO 27001/2

ISO 27001 is an internationally recognized standard for managing information security. It provides a systematic approach to securing sensitive data through an Information Security Management System (ISMS). This standard helps organizations safeguard information by identifying risks and implementing controls. ISO 27002 is a complementary standard that provides guidelines and best practices for implementing security controls outlined in ISO 27001. It offers detailed guidance on specific security measures to protect information, helping organizations to choose appropriate controls for their ISMS. ISO 27001 and 27002 provide a comprehensive framework for establishing, maintaining, and improving information security management systems (ISO -International Organisation for Standardization, 2022).

**Key features**

***Comprehensive ISMS***

Provides a structured framework for establishing, implementing, maintaining, and continuously improving an Information Security Management System (ISMS).

***Risk-Based Approach***

Focuses on identifying, assessing, and treating security risks to protect sensitive information.

***Security Controls***

ISO 27001 specifies controls, while ISO 27002 offers detailed guidance on best practices for implementing these controls.

***Compliance Focus***

Helps organizations meet legal, regulatory, and contractual information security requirements.

***Continuous Improvement***

Emphasizes regular reviews, audits, and updates to ensure the ISMS remains effective and relevant over time.

***Global Standard***

Recognized internationally, making it applicable to organizations of all sizes and industries worldwide.

## Recommendation: NIST CSF 2.0

Obsidian SecureTech Solutions recommends the NIST Cybersecurity Framework (CSF) 2.0 for Crestline Apparel Co. over other frameworks, such as ISO 27001/2 based on the following key facts from the research.

### Business Size and Operational Needs

The NIST CSF 2.0 is designed to apply to organizations of all sizes, making it particularly suitable. The structure allows the implementation of the framework incrementally, which ensures that the business prioritizes cybersecurity efforts based on current capabilities and resources. This is crucial for growing businesses like Crestline Apparel, where budget constraints and resource limitations are common. While ISO 27001 is more structured and prescriptive, it may be too complex and resource-intensive for small businesses like Crestline Apparel due to the certification costs and the manpower needed to set up and maintain an ISMS (*How Much Does ISO 27001 Certification Cost?*, n.d.).

### Industry Considerations

NIST CSF 2.0 addresses threat concerns by providing a clear roadmap for identifying and

mitigating risks. Its focus on continuous monitoring and incident response aligns well with the nature of online retail, where timely action is essential to protect customer data and maintain trust. While ISO 27001/2 would provide similar features but it's not required at the moment for a small business like Crestline Apparel because of its rigid structure compared to NIST CSF 2.0.

**Regulatory Compliance**

The NIST CSF 2.0 provides a clear framework for meeting the requirements set forth by regulations such as the California Consumer Privacy Act (CCPA, 2018), Payment Card Industry Data Security Standard (PCI-DSS, 2018), and General Data Protection Regulation (GDPR, 2018). By following the framework guidelines, the business can establish the necessary policies and procedures to protect customer data, conduct regular risk assessments, and maintain documentation that demonstrates compliance.

## Conclusion

In summary, the analysis highlights several key points regarding the adoption of the NIST Cybersecurity Framework (CSF) 2.0 for Crestline Apparel Co.:

**Scalability and Flexibility.** The framework's design allows for incremental implementation of cybersecurity measures, enabling the adoption of security strategies as the business grows while managing costs effectively.

**Regulatory Compliance.** NIST CSF 2.0 supports compliance with essential data protection laws and industry regulations, such as the CCPA, PCI-DSS, and GDPR, ensuring that the business meets legal requirements and protects customer information.

**Risk management.** This framework emphasizes a risk-based approach, allowing to identify vulnerabilities and implement appropriate safeguards tailored to business-specific needs. Continuous Improvement: By adopting the NIST CSF 2.0, the business can foster a culture of

ongoing assessment and enhancement of cybersecurity practices to ensure that it stays ahead of emerging threats.

NIST CSF 2.0 is the recommended framework for Crestline Apparel at this stage. As the business scales internationally, transitioning to ISO 27001/2 certification should be considered.

**Table 1: NIST CSF/ISO 2700 comparison on key criteria**

| Criteria | NIST CSF 2.0 | ISO 27001/2 |
|---|---|---|
| Flexibility and Scalability | **Features:** - Highly flexible and adaptable to various organization sizes and types, can be tailored to specific industry needs. **Limitations:** - May require more effort to implement due to its lack of guidance. | **Features:** - Scalable for different organization sizes, Structured approach that can be adapted according to needs. **Limitations:** - Less flexible than NIST CSF, more prescriptive and requires ISMS which can be resource intensive. |
| Global Applicability | **Features:** - Widely recognized internationally, Used by organizations mostly in U.S. **Limitations:** - Developed by a U.S. agency, which may affect adoption in some regions. | **Features:** - Internationally recognized standard, Widely adopted globally. **Limitations:** - None significant in terms of global applicability but may not align directly with local U.S regulations. |
| Certification | **Features:** - No formal certification process, Self-assessment and voluntary adoption. **Limitations:** - Lack of third-party validation may be seen as a drawback by some businesses. | **Features:** - Formal certification process available, but optional. Third-party audits for compliance. **Limitations:** - Certification process can be resource-intensive. |
| Risk Management Focus | **Features:** - Strong emphasis on risk management, Integrates risk assessment throughout the framework. **Limitations:** - May require additional guidance for comprehensive risk management. | **Features:** - Risk-based approach is a core principle, Includes specific requirements for risk assessment and treatment within ISMS. **Limitations:** - Some organizations may find the risk assessment process complex. |
| Cross-referencing | **Features:** - Extensive cross-referencing with other frameworks and standards, Facilitates integration with existing practices, can be mapped to other U.S frameworks (e.g.NIST 800-53, HIPPA etc). **Limitations:** - Keeping cross-references updated can be challenging. | **Features:** - Can be mapped to other standards e.g GDPR. **Limitations:** - Less comprehensive cross-referencing compared to NIST CSF due to global adaptability. |
| Cost | **Features:** - Framework is freely available, Implementation costs vary based on organization. **Limitations:** - May require internal resources for implementation. | **Features:** - Standard must be purchased, Implementation and certification costs involved. **Limitations:** - Higher overall costs due to certification requirements. |
| Implementation Complexity | **Features:** - Flexible implementation allows for gradual adoption. Provides guidance but not prescriptive. **Limitations:** - May require more expertise to implement effectively. | **Features:** - Structured approach with clear requirements, well-defined implementation process for setting up ISMS. **Limitations:** - Can be complex for smaller organizations and resource intensive. |
| Ongoing Maintenance | **Features:** - Encourages continuous improvement. Regular updates to the framework. **Limitations:** - Requires ongoing commitment to stay current with updates | **Features:** - Requires regular internal audits and management reviews, Continuous improvement is part of the standard **Limitations:** - Formal recertification required periodically, which can be resource-intensive. |

## References

Dempsey, K., Ross, R., & Stine, K. (2014). *Supplemental Guidance on Ongoing Authorization Transitioning to Near Real-Time Risk Management*. https://csrc.nist.rip/publications/nistpubs/800-37-rev1/nist_oa_guidance.pdf

GDPR. (2018). *General Data Protection Regulation (GDPR)*. General Data Protection Regulation (GDPR). https://gdpr-info.eu

*How much does ISO 27001 certification cost?* (n.d.). Vanta. https://www.vanta.com/collection/iso-27001/iso-27001-certification-cost

ISO. (2022, October). *ISO/IEC 27001 standard – information security management systems*. ISO. https://www.iso.org/standard/27001

National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0. *The NIST Cybersecurity Framework (CSF) 2.0*, *2.0*(29). https://doi.org/10.6028/nist.cswp.29

NIST. (2020, December 10). *Security and Privacy Controls for Information Systems and Organizations*. Csrc.nist.gov. https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final

NIST Cybersecurity Framework 2.0: (2024). *Small Business Quick Start Guide*. https://doi.org/10.6028/nist.sp.1300

PCI SECURITY STANDARDS COUNCIL. (2019, July). *Official PCI Security Standards Council Site - Verify PCI Compliance, Download Data Security and Credit Card Security Standards*. Pcisecuritystandards.org. https://www.pcisecuritystandards.org

PCI Security Standards Council. (2018). *PCI DSS Quick Reference Guide Understanding the Payment Card Industry Data Security Standard version 3.2.1 For merchants and other entities involved in payment card processing*. https://listings.pcisecuritystandards.org/documents/PCI_DSS-QRG-v3_2_1.pdf

State of California Department of Justice. (2024, March 13). *California Consumer Privacy Act (CCPA)*. State of California - Department of Justice - Office of the Attorney General. https://oag.ca.gov/privacy/ccpa